

Checklist

Incident Response

Pre-Incident Preparation

Processes and Escalation

- ☐ Define what qualifies as a security incident.
- ☐ Establish severity levels and escalation thresholds.
- ☐ Define who has the authority to declare an incident.
- ☐ Identify the incident response contact or team.
- ☐ Integrate incident response with existing outage, support, and operational processes.
- ☐ Make sure staff know how and when to report a suspected incident.
- ☐ Prefer escalating a suspected incident early rather than delaying because of a possible false positive.

Roles and Communications

- ☐ Identify who may act as the incident manager.
- ☐ Define responsibilities for technical responders.
- ☐ Define who communicates with management and internal stakeholders.
- ☐ Define who handles external communications.
- ☐ Identify legal, compliance, HR, communications, and PR contacts where appropriate.
- ☐ Document contact information for external incident-response specialists or vendors.
- ☐ Put contracts, NDAs, and service-level agreements in place before an incident occurs.

Technical Preparation

- ☐ Ensure centralized logging or SIEM capabilities are available where possible.
- ☐ Confirm logs are retained long enough to support investigations.
- ☐ Protect logs from alteration by compromised systems.

- ☐ Confirm EDR/XDR/MDR coverage across critical systems.
- ☐ Prepare methods for endpoint isolation and containment.
- ☐ Document procedures for disk imaging and memory acquisition.
- ☐ Prepare packet-capture and network-monitoring capabilities where practical.
- ☐ Test access to forensic and analysis tools before they are needed.
- ☐ Establish procedures for preserving evidence and chain of custody.
- ☐ Define policies for taking system or virtual-machine snapshots during incidents.

Incident Declaration

- ☐ Validate that the reported event may represent a security incident.
- ☐ Determine the initial severity and scope.
- ☐ Formally declare the incident when escalation criteria are met.
- ☐ Notify the incident-response team.
- ☐ Assign an incident manager.
- ☐ Record the incident start time.
- ☐ Create an incident record, ticket, case, or dedicated workspace.
- ☐ Begin a detailed activity log immediately.

Incident Management

Establish Coordination

- ☐ Open a dedicated incident "war room" or secure collaboration channel.
- ☐ Start a conference or video call if responders are distributed.
- ☐ Define who is authorized to make operational decisions.
- ☐ Assign clear owners to investigation and remediation tasks.
- ☐ Establish a regular update schedule.
- ☐ Assign one person to communicate status to internal stakeholders.
- ☐ Limit unnecessary discussion of the incident through potentially compromised communication channels.

Set Incident Goals

- ☐ Identify the immediate objectives of the response.

- ☐ Prioritize protecting people, systems, and sensitive data.
- ☐ Stop or limit attacker access.
- ☐ Determine whether the attacker has established persistence.
- ☐ Identify affected systems, accounts, applications, and data.
- ☐ Determine what may have been modified, destroyed, or stolen.
- ☐ Minimize unnecessary downtime.
- ☐ Preserve evidence needed for technical or legal investigation.

Plan for Sustained Operations

- ☐ Estimate whether the incident may require a prolonged response.
- ☐ Create responder shifts for long-running incidents.
- ☐ Protect responders from fatigue.
- ☐ Ensure clean handoffs between shifts.
- ☐ Maintain continuity of command and documentation.

Evidence Preservation

- ☐ Record every significant action taken during the incident.
- ☐ Record who performed each action and when.
- ☐ Preserve original logs before modifying affected systems.
- ☐ Copy relevant logs to a secure analysis location.
- ☐ Preserve command-line histories or terminal output where possible.
- ☐ Take system or VM snapshots when appropriate.
- ☐ Capture volatile memory before shutdown when appropriate.
- ☐ Create forensic disk images when deeper analysis is required.
- ☐ Use write-protection or forensic procedures to avoid modifying original evidence.
- ☐ Record hashes and other integrity information for collected evidence.
- ☐ Maintain chain-of-custody documentation when required.

Log Analysis

- ☐ Collect operating-system logs.
- ☐ Collect application logs.

- ☐ Collect authentication and identity logs.
- ☐ Collect firewall, VPN, proxy, DNS, and network-device logs.
- ☐ Collect security-platform and SIEM alerts.
- ☐ Look for gaps or unusual changes in logging.
- ☐ Search for indicators of compromise.
- ☐ Correlate activity across multiple systems.
- ☐ Build a timeline of suspicious events.
- ☐ Preserve copies of important logs before further analysis.
- ☐ Use approved analysis tools, scripts, or command-line utilities as needed.

EDR / XDR / MDR Investigation

- ☐ Review endpoint alerts associated with the incident.
- ☐ Identify suspicious processes and process trees.
- ☐ Review file creation, deletion, and modification events.
- ☐ Review network connections from affected endpoints.
- ☐ Identify suspicious user or service-account activity.
- ☐ Search other endpoints for matching indicators.
- ☐ Investigate signs of lateral movement.
- ☐ Investigate signs of persistence.
- ☐ Determine whether malware or attacker tools are present.
- ☐ Isolate compromised endpoints when appropriate.
- ☐ Use automated remediation only when its impact is understood.
- ☐ Preserve relevant endpoint telemetry before it expires.

Disk and File Analysis

- ☐ Determine whether a full disk image is required.
- ☐ Capture the disk using an approved forensic-imaging method.
- ☐ Preserve the original image and analyze a working copy.
- ☐ Examine active and deleted files.
- ☐ Review filesystem metadata.
- ☐ Search unallocated or slack space where appropriate.
- ☐ Look for hidden files, rootkits, or suspicious artifacts.

- ☐ Build filesystem timelines.
- ☐ Recover deleted files when useful.
- ☐ Use file-recovery tools when a full forensic examination is unnecessary.
- ☐ Document all findings.

Memory Analysis

- ☐ Capture RAM from affected systems when volatile evidence may be valuable.
- ☐ Use hypervisor-based memory capture for virtual systems where appropriate.
- ☐ Analyze memory for suspicious processes.
- ☐ Search for injected or malicious code.
- ☐ Look for credentials, encryption keys, network connections, and command history where legally and operationally appropriate.
- ☐ Identify memory-resident malware.
- ☐ Correlate memory findings with disk, endpoint, and network evidence.
- ☐ Preserve memory images for later analysis.

Network / PCAP Analysis

- ☐ Collect available packet captures.
- ☐ Review IDS/IPS and network-monitoring alerts.
- ☐ Identify suspicious source and destination IP addresses.
- ☐ Identify unusual ports and protocols.
- ☐ Review DNS activity.
- ☐ Identify command-and-control traffic.
- ☐ Identify evidence of data exfiltration.
- ☐ Filter large captures into smaller investigation sets when needed.
- ☐ Analyze suspicious sessions and individual connections.
- ☐ Correlate network activity with endpoint and log evidence.

Common Analysis Tools

- ☐ Use `tcpdump` or equivalent tools for command-line packet inspection.
- ☐ Use Wireshark for detailed protocol and session analysis.
- ☐ Use TShark for command-line Wireshark analysis.

- ☐ Use IDS-style analysis tools such as Snort or Zeek where appropriate.
- ☐ Use trusted forensic toolkits or dedicated incident-response environments when required.

Containment

- ☐ Identify the systems and accounts that must be contained first.
- ☐ Isolate compromised endpoints where appropriate.
- ☐ Disable or restrict compromised accounts.
- ☐ Block malicious IP addresses, domains, URLs, hashes, or other indicators where appropriate.
- ☐ Restrict affected network segments if necessary.
- ☐ Preserve evidence before destructive remediation whenever possible.
- ☐ Consider whether containment actions could alert the attacker.
- ☐ Confirm that containment has not unnecessarily disrupted critical services.
- ☐ Monitor for continued attacker activity after containment.

Eradication

- ☐ Remove malware and attacker tools.
- ☐ Remove persistence mechanisms.
- ☐ Delete unauthorized accounts.
- ☐ Remove malicious scheduled tasks, services, startup items, or configuration changes.
- ☐ Patch exploited vulnerabilities.
- ☐ Correct security misconfigurations.
- ☐ Reset compromised passwords and credentials.
- ☐ Rotate exposed API keys, tokens, certificates, or secrets.
- ☐ Rebuild systems where trust cannot be restored.
- ☐ Hunt for the same compromise across the wider environment.
- ☐ Verify that all known attacker access paths have been closed.

Recovery

- ☐ Restore affected systems from trusted sources.
- ☐ Validate system integrity before returning systems to production.
- ☐ Restore required data.
- ☐ Confirm security patches and configuration changes are in place.
- ☐ Reconnect systems gradually where appropriate.
- ☐ Monitor restored systems closely.
- ☐ Watch for recurring indicators of compromise.
- ☐ Confirm business services are functioning correctly.
- ☐ Obtain appropriate approval before declaring recovery complete.

Communications

Internal

- ☐ Keep responders updated through the dedicated incident channel.
- ☐ Provide management with regular, concise status updates.
- ☐ Clearly distinguish confirmed facts from assumptions.
- ☐ Document major decisions and their owners.
- ☐ Maintain a single authoritative source of incident status.

External

- ☐ Determine whether customers, partners, insurers, regulators, or law enforcement must be contacted.
- ☐ Coordinate external messaging with legal and communications teams.
- ☐ Review contractual and regulatory notification deadlines.
- ☐ Avoid releasing unverified technical details.
- ☐ Keep a record of all external notifications and communications.

Incident Closure

- ☐ Confirm that attacker access has been removed.
- ☐ Confirm persistence mechanisms have been eliminated.
- ☐ Confirm affected systems have been recovered.
- ☐ Confirm monitoring is in place for recurrence.

- ☐ Resolve or transfer remaining operational tasks.
- ☐ Record the incident end time.
- ☐ Obtain approval from the incident manager to close the active response.

Post-Incident Review

- ☐ Schedule a lessons-learned or postmortem session shortly after the incident.
- ☐ Give responders enough time to recover and gather accurate information before the review.
- ☐ Build a final incident timeline.
- ☐ Document the root cause where it can be determined.
- ☐ Document the initial attack vector.
- ☐ Document the systems, accounts, and data affected.
- ☐ Identify what worked well.
- ☐ Identify what did not work well.
- ☐ Review delays, communication problems, and coordination issues.
- ☐ Review detection and monitoring gaps.
- ☐ Review the effectiveness of containment and recovery actions.
- ☐ Identify required process improvements.
- ☐ Identify required technology improvements.
- ☐ Identify required training.
- ☐ Update incident-response documentation.
- ☐ Update policies and procedures.
- ☐ Update detection rules and security controls.
- ☐ Conduct additional drills or tabletop exercises as needed.
- ☐ Assign owners and deadlines to corrective actions.
- ☐ Produce an after-action report.
- ☐ Track remediation items through completion.

Final Verification

- ☐ All evidence has been preserved appropriately.
- ☐ The incident timeline is complete.
- ☐ Technical findings have been documented.
- ☐ Required internal and external notifications are complete.

- ☐ Systems have been securely restored.
- ☐ Credentials and secrets have been rotated where necessary.
- ☐ Monitoring has been enhanced for identified threats.
- ☐ Lessons learned have been incorporated into procedures.
- ☐ Follow-up actions have owners and deadlines.
- ☐ The incident is formally closed.